

CISA Complete Study Notes

| All 5 Domains — Information Systems Audit & Control

CHAPTER 1 — Information System Auditing Process

PART A: PLANNING

1.1 IS Audit Standards, Guidelines & Ethics

1.1.1 ISACA IS Audit and Assurance Standards

- Define **mandatory** requirements for IS auditing
- Set minimum performance levels for IS auditors
- Three categories: General, Performance, Reporting standards

1.1.2 ISACA IS Audit and Assurance Guidelines

- Provide **guidance** on how to apply standards (not mandatory)
- Help auditors understand HOW to meet standards
- Cover specific audit topics and scenarios

1.1.3 ISACA Code of Professional Ethics

Key principles auditors must follow:

- Support the implementation of, and encourage compliance with, standards/procedures
- Perform duties with objectivity, due diligence and professional care
- Serve in the interest of stakeholders in a lawful and honest manner
- Maintain privacy and confidentiality of information obtained
- Maintain competency in their respective fields
- Inform appropriate parties of results of work performed
- Support professional education of management and users

1.1.4 ITAF™ (IT Assurance Framework)

- ISACA's comprehensive framework for IT audit professionals

- Provides structure for IS audit professionals
- Includes standards, guidelines and tools/techniques

1.1.5 IS Internal Audit Function

Audit Charter

- Formal document defining purpose, authority and responsibility of audit function
- Approved by senior management or audit committee
- Establishes independence and access rights

Management of the IS Audit Function

- Must be independent from audited areas
- Requires qualified, competent staff
- Should have direct reporting to audit committee

IS Audit Resource Management

- Plan staffing to match audit assignments
- Balance between in-house and outsourced audit resources
- Ensure competency in IT-specific skills

Using Services of Other Auditors and Experts

- May use specialists (e.g., legal, IT security experts)
- IS auditor remains responsible for the work
- Must assess competency of experts used

1.2 Types of Audits, Assessments and Reviews

1.2.1 Control Self-Assessment (CSA)

A technique that allows management and work teams to assess their own controls.

Objectives of CSA

- Identify risks and exposures
- Raise risk awareness among staff
- Supplement traditional auditing (not replace it)
- Detect fraud, waste and errors early

Benefits of CSA

- Early detection of risks by people closest to operations
- Increased employee awareness and ownership of controls
- More timely and cost-effective than full audits
- Improved communication between auditors and management

Disadvantages of CSA

- Participants may not be objective
- May miss risks participants are unaware of
- Time-consuming for business units
- Risk of "rubber stamping" controls

IS Auditor's Role in CSA

- Facilitator or observer (not assessor)
- Reviews and validates CSA results
- Maintains independence while supporting the process

1.2.2 Integrated Auditing

- Combines financial, operational and IS audit activities
 - More efficient — reduces duplicate testing
 - Provides holistic view of risk and control
 - Requires auditors with both IT and business knowledge
-

1.3 Risk-Based Audit Planning

1.3.1 Individual Audit Assignments

- Define scope, objectives, and resources needed
- Align with overall audit universe and risk assessment
- Document in audit program before fieldwork begins

1.3.2 Effect of Laws and Regulations on IS Audit Planning

- Regulatory requirements shape audit priorities (SOX, HIPAA, GDPR, PCI-DSS)
- Non-compliance can result in fines, penalties, legal action

- Auditor must stay current on applicable laws

1.3.3 Audit Risk and Materiality

Risk Type	Definition
Inherent Risk	Risk existing before any controls
Control Risk	Risk that controls fail to prevent/detect errors
Detection Risk	Risk that auditor's procedures miss significant errors
Overall Audit Risk	$\text{Inherent Risk} \times \text{Control Risk} \times \text{Detection Risk}$

Materiality — threshold above which errors/omissions would affect decisions of users

1.3.4 Risk Assessment

- Identifies areas of highest risk for audit focus
- Should be performed at enterprise level (annual) and engagement level
- Considers probability and impact of risk events

1.3.5 IS Audit Risk Assessment Techniques

- Questionnaires and checklists
- Interviews with management
- Prior audit findings review
- Benchmarking against industry standards
- Analytical procedures

1.3.6 Risk Analysis

- **Qualitative** — descriptive (High/Medium/Low)
 - **Quantitative** — numerical ($\text{ALE} = \text{ARO} \times \text{SLE}$)
 - ALE = Annual Loss Expectancy
 - ARO = Annual Rate of Occurrence
 - SLE = Single Loss Expectancy
-

1.4 Types of Controls and Considerations

1.4.1 Internal Controls

Primary purposes:

- Safeguard assets
- Ensure reliability of financial and operational information
- Promote efficiency and effectiveness
- Ensure compliance with laws and regulations

1.4.2 Control Objectives and Measures

- **IS Control Objectives** — high-level statements of desired results
- **General Control Methods** — apply across all IS (access controls, change management)
- **IS-Specific Controls** — application-level controls
- **Business Process Application Controls** — embedded in applications

1.4.3 Control Classifications

By Nature	By Function
Preventive	Detective
Detective	Corrective
Corrective	Deterrent
Compensating	Recovery

1.4.4 Control Relationship to Risk

- Controls reduce inherent risk to an acceptable residual risk level
- **Residual Risk** = Inherent Risk – Control Effectiveness
- When controls fail → control risk increases

1.4.5 Prescriptive Controls and Frameworks

- COBIT (Control Objectives for IT)
- ISO 27001 / ISO 27002
- NIST Cybersecurity Framework

- ITIL (IT Infrastructure Library)

1.4.6 Evaluation of Control Environment

- **Management Control Monitoring** — ongoing monitoring by management
 - **Independent Evaluation** — external or internal audit review
 - Both are needed for effective control environment
-

PART B: EXECUTION

1.5 Audit Project Management

1.5.1 Audit Objectives

- Define what the audit aims to achieve
- Must be clear, measurable and agreed upon before fieldwork
- Types: Compliance, Operational, Financial, IT-specific

1.5.2 Audit Phases

Phase	Key Activities
Planning	Define scope, objectives, risk assessment, audit program
Fieldwork / Documentation	Execute tests, gather evidence, document findings
Reporting	Communicate findings, recommendations to management
Follow-Up	Verify management has implemented corrective actions

1.5.3 Audit Programs

- Detailed document listing specific audit procedures
- Created before fieldwork begins
- **Minimum Skills Required:** Understanding of IT environment, audit techniques, relevant regulations

1.5.4 Audit Work Papers

- Documentation of all audit work performed

- Must be complete, accurate, and organized
- Serve as evidence supporting audit conclusions
- Must be securely stored and retained per policy

1.5.5 Fraud, Irregularities and Illegal Acts

- Auditor should be alert for signs of fraud during any audit
- **Red flags:** Unusual transactions, overridden controls, lifestyle changes
- Auditor does NOT investigate fraud — reports suspicions to appropriate authority
- Maintain chain of custody if fraud is found

1.5.6 Agile Auditing

Overview

- Applies Agile principles to audit process
- Iterative, flexible, collaborative approach
- Shorter audit cycles with continuous feedback

Benefits

- Faster delivery of audit results
- Better stakeholder engagement
- More responsive to changing risk environment
- Continuous improvement mindset

Agile vs. Traditional Auditing

- Traditional: Linear, sequential phases
 - Agile: Iterative sprints, ongoing communication
 - Both must still comply with ISACA standards
-

1.6 Audit Testing and Sampling Methodology

1.6.1 Compliance vs. Substantive Testing

Testing Type	Purpose
Compliance Testing	Tests whether controls exist and are functioning
Substantive Testing	Tests accuracy and completeness of data/transactions

1.6.2 Sampling

Why Sample? — Testing entire population is impractical

Sampling Methods:

- **Statistical Sampling** — mathematically based, allows projection to population
 - Random sampling, Systematic sampling, Stratified sampling
- **Non-Statistical (Judgmental) Sampling** — based on auditor's judgment
 - Haphazard sampling, Block sampling

Sampling Risk

- **Type I Error (Alpha Risk)** — Rejecting a good population (under-reliance)
 - **Type II Error (Beta Risk)** — Accepting a bad population (over-reliance) — MORE DANGEROUS
-

1.7 Audit Evidence Collection Techniques

1.7.1 Interviewing and Observing Personnel

- **Interviews** — gather information about processes and controls
 - **Observation** — watch processes being performed in real-time
 - **Reperformance** — auditor re-executes control to verify it works
 - **Inspection** — review physical documents and records
 - Evidence must be: **Sufficient, Reliable, Relevant, Useful**
-

1.8 Audit Data Analytics

1.8.1 Computer-Assisted Audit Techniques (CAATs)

- Software tools used by auditors to analyze large data sets

- Types: ACL, IDEA, embedded audit modules
- Can test 100% of population (not just samples)
- Used for: Sorting, stratification, duplicate detection, gap analysis

CAATs as Continuous Online Audit Approach

- Automated data extraction and analysis
- Can run continuously in background
- Alerts auditor to anomalies in real-time

1.8.2 Continuous Auditing and Monitoring

- **Continuous Auditing** — automated audit procedures run frequently
- **Continuous Monitoring** — management-level ongoing oversight
- Both use technology to provide near real-time assurance

1.8.3 Continuous Auditing Techniques

- Embedded audit modules (EAMs)
- Snapshot and extended records
- SCARF (System Control Audit Review File)
- Audit hooks — triggers within application software

1.8.4 Artificial Intelligence in IS Audit

Audit Algorithms

- Automated rules-based or ML-driven analysis
- Can identify patterns humans would miss

Interpretation of AI/ML Results

- Auditor must understand model logic
- Cannot treat AI output as definitive without review

AI/ML Audit Risk and Considerations

- Model bias and explainability
- Data quality issues
- Regulatory compliance of AI systems
- Model drift over time

1.9 Reporting and Communication Techniques

1.9.1 Communicating Audit Results

- Draft report shared with management for factual accuracy
- Final report issued after management response
- Must be timely — delays reduce value

1.9.2 Audit Report Objectives

- Communicate findings clearly
- Provide actionable recommendations
- Support management decision-making
- Create accountability

1.9.3 Audit Report Structure and Contents

1. Executive Summary
2. Background / Scope and Objectives
3. Findings (ranked by risk/severity)
4. Recommendations
5. Management Response / Action Plan
6. Conclusion

1.9.4 Audit Documentation

- Work papers support all report findings
- Must be retained per organizational retention policy
- Confidential — access limited to authorized personnel

1.9.5 Follow-Up Activities

- Verify management has implemented agreed remediation
- Test whether corrective actions are effective
- Re-issue findings if not addressed within agreed timeframe

1.9.6 Types of IS Audit Reports

- **Unqualified (Clean)** — no material issues found

- **Qualified** — specific exception noted
 - **Adverse** — major issues; controls are inadequate
 - **Disclaimer** — auditor unable to form an opinion
-

1.10 Quality Assurance and Improvement

1.10.1 Audit Committee Oversight

- Independent board-level body overseeing audit function
- Approves audit charter and annual audit plan
- Receives audit reports directly from IS audit function

1.10.2 Audit Quality Assurance

- Internal QA reviews of audit work papers
- External quality assessments (peer review)
- Conformance with ISACA standards

1.10.3 Audit Team Training and Development

- Continuing Professional Education (CPE) requirements
- Technical certifications (CISA, CISSP, CISM)
- On-the-job mentoring and supervision

1.10.4 Monitoring

- Track audit recommendation status
 - KPIs for audit function performance
 - Feedback from auditees and management
-

CHAPTER 2 — Governance and Management of IT

PART A: IT GOVERNANCE

2.1 Laws, Regulations and Industry Standards

2.1.1 Impact on IS Audit

- Laws drive mandatory controls (HIPAA, SOX, GDPR, PCI-DSS)
- Non-compliance = legal liability, reputational damage
- Auditors must identify all applicable regulations for each audit

2.1.2 Governance, Risk and Compliance (GRC)

- Integrated framework linking governance, risk management and compliance
 - Reduces redundancy in controls and reporting
 - Enables consistent risk-based decision making
-

2.2 Organizational Structure, IT Governance and IT Strategy

2.2.1 Enterprise Governance of Information and Technology (EGIT)

- Framework ensuring IT is aligned with business objectives
- Covers accountability, performance and compliance
- Board and senior management are ultimately responsible

2.2.2 Good Practices for EGIT

- IT governance aligned with corporate governance
- Clear roles and responsibilities
- Performance measurement and reporting
- Risk management integrated into governance

2.2.3 Audit's Role in EGIT — Three Lines Model

Line	Role
1st Line	Operational management — owns and manages risk
2nd Line	Risk and compliance functions — oversight
3rd Line	Internal audit — independent assurance

2.2.4 Information Security Governance

Effective Information Security Governance includes:

- Security strategy aligned with business strategy
- Security policies approved by senior management
- Defined roles and accountability
- Metrics and reporting to board
- Compliance with legal/regulatory requirements

2.2.5 Information Systems Strategy

- IT strategy should support and enable business strategy
- Strategic alignment is a key governance principle
- IT strategy reviewed and updated regularly

2.2.6 Strategic Planning

- Long-term (3–5 year) IT plans
- Includes technology roadmaps, investment plans
- Risk-based prioritization of IT initiatives

2.2.7 Business Intelligence

- Use of data analytics to support decision-making
- Tools: dashboards, data warehouses, predictive analytics
- Governance of BI tools is an audit consideration

2.2.8 Organizational Structure

IT Governing Committees

- IT Steering Committee — strategic direction
- IT Governance Committee — policy and oversight
- Change Advisory Board (CAB) — change management

Senior Management and Board Roles

- Accountable for IT risk and governance
- Must receive regular IT performance and risk reporting

- Approve IT strategy and major investments

Separation of Duties (SoD)

- Critical IS control — prevents single person from controlling entire process
- Key SoD examples: Developer ≠ Production access; Initiator ≠ Approver
- Compensating controls when SoD not possible: logs, supervision, reconciliation

2.2.9 Auditing IT Governance

- Review governance documentation and policies
 - Assess committee meeting minutes
 - Interview senior management
 - Compare to COBIT or other frameworks
-

2.3 IT Policies, Standards, Procedures and Guidelines

Document	Nature	Frequency of Change
Policy	High-level mandatory intent	Infrequent
Standard	Specific mandatory requirements	Moderate
Procedure	Step-by-step instructions	More frequent
Guideline	Recommended (optional)	As needed

Information Security Policy Requirements

- Approved by senior management
 - Communicated to all users
 - Reviewed at least annually
 - Covers: access control, incident response, acceptable use, classification
-

2.4 Enterprise Architecture

- Blueprint for aligning IT assets with business strategy
- Common frameworks: TOGAF, Zachman, FEA

- Auditors review EA for completeness and currency
-

2.5 Enterprise Risk Management (ERM)

2.5.1 Developing a Risk Management Program

- Risk appetite defined by board
- Risk tolerance = acceptable variance from risk appetite
- ERM integrates all enterprise risk categories

2.5.2 Risk Management Life Cycle

Step 1: Risk Identification

- Identify threats and vulnerabilities
- Sources: interviews, checklists, incident history, business context

Step 2: Risk Assessment

- Analyze likelihood and impact
- Prioritize risks for treatment

Step 3: Risk Response and Mitigation Four options:

- **Accept** — live with the risk
- **Avoid** — eliminate the risk source
- **Transfer** — shift risk (insurance, contracts)
- **Mitigate** — reduce likelihood or impact

Step 4: Risk and Control Monitoring and Reporting

- Ongoing monitoring via KRIs
- Regular reporting to management and board

2.5.3 Risk Analysis Methods

- **Qualitative** — descriptive ratings (High/Medium/Low), subjective
 - **Semiquantitative** — numerical scales assigned to qualitative ratings
 - **Quantitative** — mathematical calculations (ALE, ROI on controls)
-

2.6 Data Privacy Program and Principles

2.6.1 Privacy Documentation

- Privacy policy (public-facing)
- Privacy notices (data subject notices)
- Data processing agreements
- Records of processing activities (ROPA)

2.6.2 Audit Process for Privacy

- Review privacy documentation completeness
 - Test consent mechanisms
 - Verify data subject rights are implemented
 - Assess cross-border transfer controls
-

2.7 Data Governance and Classification

2.7.1 Data Inventory and Classification

- Data inventory = catalog of all data assets
- Classification levels (e.g., Public, Internal, Confidential, Secret)
- Data owner assigns classification; IT enforces controls

2.7.2 Legal Purpose, Consent and Legitimate Interest

- **Legal Purpose** — processing must have lawful basis
- **Consent** — must be freely given, specific, informed, unambiguous
- **Legitimate Interest** — balance test required; must not override data subject rights

2.7.3 Data Subject Rights (GDPR principles)

- Right to access
- Right to rectification
- Right to erasure ("right to be forgotten")
- Right to data portability
- Right to object
- **Transborder Data Flow** — restrictions on transferring data outside jurisdiction

PART B: IT MANAGEMENT

2.8 IT Resource Management

2.8.1 Value of IT

- IT should deliver measurable business value
- Value realization measured through benefits tracking

2.8.2 IT Portfolio Management

- Treat IT investments as a portfolio
- Balance risk, return and strategic alignment
- Prioritize based on business value and risk

2.8.4 Human Resource Management

Key HR controls auditors review:

- **Background checks** — pre-employment screening
- **Employee handbook** — policies acknowledged at hire
- **Training** — security awareness, job-specific
- **Separation of duties** — in job design
- **Mandatory vacations** — helps detect fraud (someone must cover)
- **Termination policies** — immediate access revocation
- **Non-disclosure agreements** — protect confidential information

2.8.5 Enterprise Change Management

- Formal process for requesting, approving, testing and implementing changes
- Change types: Normal, Standard, Emergency
- Change Advisory Board (CAB) reviews significant changes

2.8.6 Financial Management

- **Cost Allocation** — IT costs allocated to business units
 - **IS Budgets** — capital vs. operating budgets
 - **Capitalization vs. Expensing** — software development costs per accounting rules
-

2.9 IT Vendor Management

2.9.1 Sourcing Practices

- In-house vs. outsource decision based on core competency
- Vendor selection based on capability, cost, risk, references

2.9.2 Outsourcing Practices

- SLAs must define performance expectations
- Right to audit clauses in vendor contracts
- SOC 2 reports provide audit evidence for outsourced services

SOC Report Types:

Report	Purpose
SOC 1	Financial reporting controls
SOC 2	Security, availability, confidentiality, processing integrity, privacy
SOC 3	General use summary of SOC 2

2.9.3 Cloud Governance

- Shared responsibility model defines what client vs. cloud provider controls
- Review cloud contracts for: data ownership, audit rights, exit provisions
- Monitor SLAs and security controls

2.9.4 Governance in Outsourcing

- Oversight does not transfer with outsourcing
- Governance framework must extend to vendors

2.10 IT Performance Monitoring and Reporting

Indicator	What it Measures
KPI (Key Performance Indicator)	Achieving performance goals

Indicator	What it Measures
KRI (Key Risk Indicator)	Early warning of increasing risk
KCI (Key Control Indicator)	Effectiveness of controls

2.10.5 Performance Approaches

- **Six Sigma** — reduce process defects (DMAIC methodology)
- **Agile/Business Agility** — flexible, iterative improvement
- **IT Balanced Scorecard** — four perspectives: Financial, Customer, Internal Processes, Learning & Growth

2.11 Quality Assurance and Quality Management

- **QA** — proactive, built into processes
- **QM** — comprehensive management of quality across organization
- **Operational Excellence** — continuous improvement culture, eliminate waste (Lean principles)

CHAPTER 3 — Information Systems Acquisition, Development and Implementation

PART A: IS ACQUISITION AND DEVELOPMENT

3.1 Project Governance and Management

3.1.4 Project Management Techniques

- **WBS** (Work Breakdown Structure) — decomposes project into tasks
- **Gantt Charts** — timeline view of tasks and dependencies
- **PERT/CPM** — critical path analysis for scheduling
- **Earned Value Management (EVM)** — integrates scope, schedule, cost

3.1.5 Portfolio/Program Management

- **Portfolio** = collection of projects

- Program = group of related projects managed together
- PMO oversees all projects at enterprise level

3.1.9 Project Objectives (SMART)

- Specific, Measurable, Achievable, Relevant, Time-bound

3.1.10 Project Planning — Cost Estimation

- **Function Point Analysis** — estimates size based on functionality
- **Software Size Estimation** — LOC (lines of code) based
- **Bottom-up Estimating** — detail task-level estimates
- **Analogous Estimating** — based on similar past projects

3.1.12 Project Controlling and Monitoring

- Manage scope changes through formal change control
 - Monitor resource usage vs. plan
 - Manage project risks continuously
-

3.2 Business Case and Feasibility Analysis

Types of feasibility:

- **Technical** — can it be built?
 - **Financial/Economic** — is it worth the cost?
 - **Operational** — will users adopt it?
 - **Legal/Regulatory** — is it compliant?
 - **Schedule** — can it be done in time?
-

3.3 System Development Methodologies

3.3.2 SDLC Models

- Waterfall — linear, sequential
- Iterative — repeated cycles
- Spiral — risk-driven iterations

- **Agile** — short sprints, working software incrementally

3.3.3 SDLC Phases

Phase	Key Activities
1. Feasibility Study	Assess viability; business case
2. Requirements Definition	Gather and document user requirements
3A. Software Selection	Evaluate buy vs. build; RFP process
3B. Design	System architecture, database, UI design
4A. Configuration	Configure COTS/SaaS systems
4B. Development	Code writing, unit testing
5. Testing & Implementation	Integration, UAT, cutover
6. Post-Implementation Review	Assess whether objectives were met

3.3.5 Software Development Methods

Method	Key Characteristics
Prototyping	Early working model; user feedback drives design
RAD	Rapid delivery; user involvement throughout
Agile/Scrum	2-4 week sprints; backlog-driven; working software
Object-Oriented	Encapsulation, inheritance, polymorphism
DevOps	Integration of Dev and Ops; CI/CD pipelines
DevSecOps	Security integrated into DevOps pipeline

3.3.6 System Development Tools

- **CASE Tools** — automated support for SDLC activities
- **Code Generators** — auto-generate code from specifications
- **4GLs** — higher-level languages reducing coding effort

3.4 Control Identification and Design

3.4.1 Application Controls

Input Controls

- Field validation (format, range, type checks)
- Check digits — detect transposition errors
- Sequence checks — ensure no gaps in numbering
- Completeness checks — required fields filled
- Batch totals — verify sum of transactions

Processing Controls

- Run-to-run totals — balance from start to end of processing
- Edit checks — validate data during processing
- Error handling and correction procedures

3.4.2 Output Controls

- Report balancing — tie output totals to input totals
 - Report distribution controls — authorized recipients only
 - Output review — management review for reasonableness
-

PART B: IS IMPLEMENTATION

3.5 System Readiness and Implementation Testing

3.5.1 Testing Classifications

Test Type	Purpose
Unit Testing	Individual program modules (by developer)
Integration Testing	Interfaces between modules
System Testing	Entire system against requirements
UAT (User Acceptance Testing)	End users validate system meets needs
Regression Testing	Verify changes didn't break existing functionality
Performance/Load Testing	System behavior under expected/peak loads
Stress Testing	System behavior beyond normal capacity
Penetration Testing	Security vulnerabilities
Parallel Testing	New and old systems run simultaneously

3.6 Implementation Configuration and Release Management

Configuration Management

- Track and control changes to system components
- Configuration Management Database (CMDB) — repository of IT assets
- Baseline configurations established and maintained

3.7 System Migration, Infrastructure Deployment and Data Conversion

3.7.2 Changeover (Go-Live) Techniques

Method	Description	Risk
Parallel	Old and new systems run simultaneously	Low — most expensive
Phased	Gradual rollout by module or user group	Medium
Abrupt (Big Bang)	Complete cutover at once	High — cheapest
Pilot	Rollout to subset of users first	Medium-Low

3.7.1 Data Migration

- Data cleansing before migration
 - Reconciliation of migrated data
 - **Fallback/Rollback Scenario** — plan to revert to old system if migration fails
-

3.8 Post-Implementation Review

- Compare actual vs. planned outcomes
 - Assess whether business objectives were achieved
 - Document lessons learned
 - IS Auditor evaluates: controls, data integrity, user satisfaction, performance
-

CHAPTER 4 — Information Systems Operations and Business Resilience

PART A: INFORMATION SYSTEMS OPERATIONS

4.1 IT Components

4.1.1 Networking

LAN (Local Area Network) — limited geographic area **WAN** (Wide Area Network) — geographic distance; uses leased lines, MPLS

OSI Reference Model (7 Layers — memorize!):

Layer	Name	Function
7	Application	User interfaces, HTTP, FTP, SMTP
6	Presentation	Encryption, compression, translation
5	Session	Session management, authentication
4	Transport	End-to-end delivery, TCP/UDP
3	Network	Routing, IP addressing
2	Data Link	MAC addressing, switches
1	Physical	Cables, hubs, bits

TCP/IP Model (4 layers): Application, Transport, Internet, Network Access

Network Address Translation (NAT)

- Maps private internal IP addresses to public external IP
- Provides basic security (hides internal addressing)

4.1.2 Computer Hardware

- CPU — central processing unit
- Memory hierarchy: Cache → RAM → SSD/HDD → Tape
- I/O devices: keyboards, network cards, storage controllers

4.1.3 Proxy Servers

- Intermediate server between users and internet
- Provides content filtering, caching, anonymization
- Logs all user requests (useful for auditing)

4.1.4 USB Mass Storage Risks

- Unauthorized data exfiltration
 - Introduction of malware
 - Controls: Disable USB ports, DLP tools, encryption of USB devices, policy
-

4.2 IT Asset Management

- Maintain inventory of all hardware and software assets
 - Track lifecycle: acquisition → operation → disposal
 - Secure disposal (data wiping/destruction) critical
-

4.3 Job Scheduling and Production Process Automation

- Automated scheduling software runs batch jobs
 - Audit considerations: job logs, error handling, scheduling conflicts
 - Review job completion reports regularly
-

4.4 System Interfaces

Risks: Data corruption, unauthorized data sharing, timing failures **Controls:** Hash totals, checksums, reconciliation, logging of interface activity

4.5 End-User Computing (EUC) and Shadow IT

- **EUC** — spreadsheets, databases built by business users
 - **Shadow IT** — IT systems deployed without IT approval
 - Risks: lack of controls, data integrity issues, security vulnerabilities
 - Controls: EUC policy, inventory of EUC systems, access controls
-

4.6 Systems Availability and Capacity Management

Operating System Controls

- Access control enforcement
- Memory management
- Process management and audit trails

Capacity Management

- Monitor CPU, memory, storage, network utilization

- Forecast future requirements
 - Plan upgrades before capacity thresholds reached
-

4.7 Problem and Incident Management

4.7.2 Incident Handling Process

1. Detection and Identification
2. Containment
3. Eradication
4. Recovery
5. Post-incident review / Lessons Learned

Problem Management — root cause analysis of recurring incidents

4.8 IT Change, Configuration and Patch Management

4.8.1 Patch Management

- Regularly apply security patches
- Test patches in non-production before deployment
- Track unpatched systems (vulnerability risk)
- Emergency patching process for critical zero-days

Change Management Process:

1. Change request submitted
 2. Impact assessment
 3. CAB approval
 4. Testing
 5. Implementation
 6. Review and close
-

4.9 Operational Log Management

Types of Logs

- Security logs (authentication, authorization)
- System logs (OS events)
- Application logs (transactions, errors)
- Network logs (firewall, IDS)
- Database logs (queries, schema changes)

Log Management Best Practices

- Centralized collection (SIEM)
 - Tamper-evident storage
 - Retention per legal/regulatory requirements
 - Regular review and alerting
-

4.10 IT Service Level Management

- **SLA** (Service Level Agreement) — formal agreement between IT and business
 - Includes: availability targets, response times, escalation procedures
 - Monitor SLA compliance and report regularly
 - SLAs should align with business criticality
-

4.11 Database Management

4.11.2 Database Models

Model	Characteristics
Hierarchical	Tree structure, parent-child relationships
Network	Multiple parent relationships allowed
Relational (RDBMS)	Tables, rows, columns; SQL; most common
Object-Oriented	Objects with attributes and methods
NoSQL	Key-value, document, graph; unstructured data

Database Controls

- Access controls (views, stored procedures)
 - Referential integrity
 - Transaction logging
 - Backup and recovery
 - Encryption of sensitive fields
-

PART B: BUSINESS RESILIENCE

4.12 Business Impact Analysis (BIA)

- Identifies critical business processes
 - Determines impact of disruption on each process
 - Establishes:
 - **RTO** — Recovery Time Objective (max acceptable downtime)
 - **RPO** — Recovery Point Objective (max acceptable data loss)
 - **MTD** — Maximum Tolerable Downtime
 - **MTTR** — Mean Time to Repair
-

4.13 System and Operational Resilience

- Application resiliency: clustering, load balancing, failover
 - Telecom resilience: redundant circuits, diverse routing
 - Single points of failure must be identified and eliminated
-

4.14 Data Backup, Storage and Restoration

4.14.3 Backup Schemes

Scheme	What It Backs Up	Restore Complexity
Full	Everything every time	Simple
Incremental	Changes since last backup	Complex (need all incrementals)
Differential	Changes since last full	Medium

3-2-1 Backup Strategy:

- 3 copies of data
- 2 different media types
- 1 offsite copy

Offsite Storage Controls:

- Physically secure location
 - Environmental controls (fire, flood, temperature)
 - Access restricted to authorized personnel
 - Regular testing of restore capability
-

4.15 Business Continuity Plan (BCP)

BCP Process:

1. Initiate and manage the BCP project
2. Business Impact Analysis
3. Develop recovery strategies
4. Develop the plan
5. Test, maintain and update the plan

Components of a BCP:

- Emergency response procedures
- Crisis communication plan
- Business recovery procedures
- Key personnel contact lists
- Vendor/supplier contacts
- Insurance documentation

4.15.9 Plan Testing Methods

Method	Description
Checklist/Desk Review	Review plan documentation only
Structured Walk-Through	Team reviews plan step-by-step
Simulation	Simulate disruption, no actual failover
Parallel Test	Backup site activated, production continues
Full Interruption	Production systems actually shut down

4.16 Disaster Recovery Plans (DRP)

4.16.2 Recovery Strategies

Strategy	RTO	Cost
Cold Site	Days to weeks	Low
Warm Site	Hours to days	Medium
Hot Site	Minutes to hours	High
Mobile Recovery	Variable	Variable
Cloud Recovery	Minutes	Pay-per-use
Reciprocal Agreement	Variable	Low/risk

DRP Contents:

- Invocation criteria and process
- Recovery team roles and responsibilities
- Technical recovery procedures
- Communication plan
- Testing and maintenance schedule

CHAPTER 5 — Protection of Information Assets

PART A: INFORMATION ASSET SECURITY AND CONTROL

5.1 Information Asset Security Policies, Frameworks, Standards

Key Security Frameworks:

- **ISO 27001/27002** — ISMS standard and code of practice
- **NIST CSF** — Identify, Protect, Detect, Respond, Recover
- **CIS Controls** — 18 critical security controls
- **COBIT** — IT governance and control framework

Security Policy Requirements:

- Written, approved by senior management
 - Communicated to all employees
 - Enforced and reviewed annually
 - Covers all major security domains
-

5.2 Physical and Environmental Controls

Environmental Controls:

- Fire suppression (halon/FM-200 for data centers)
- HVAC — temperature and humidity control
- Raised flooring — flood protection, cable management
- UPS — uninterruptible power supply
- Generator — extended power outage backup

Physical Access Controls:

- Mantraps/airlocks — prevent tailgating
- Badge/smart card access
- Biometric readers
- CCTV surveillance
- Visitor logs and escort policies
- Security guards

ICS (Industrial Control Systems) Security:

- SCADA systems controlling physical infrastructure
 - Air-gapping, network segmentation from corporate IT
 - Special patch management considerations
-

5.3 Identity and Access Management (IAM)

5.3.1 IAM Life Cycle

1. Provisioning — account creation with appropriate access
2. Maintenance — access reviews, modifications
3. De-provisioning — timely revocation on separation/role change

5.3.2 Authentication, Authorization and Accountability

Authentication Factors:

- Something you **know** — password, PIN
- Something you **have** — token, smart card
- Something you **are** — biometric
- MFA = two or more factors combined

Authorization

- What the authenticated user is permitted to do
- Principle of Least Privilege — minimum access needed
- Need-to-Know principle — access only to required data

Accountability

- Logging all actions to individual users
- Non-repudiation — cannot deny actions taken

5.3.3 Zero-Trust Architecture (ZTA)

- "Never trust, always verify"
- Verify every user and device, regardless of location
- Microsegmentation of networks

- Continuous validation of access

5.3.4 Privileged Access Management (PAM)

- Special controls for admin/superuser accounts
- Just-in-time access, session recording, vault for credentials
- Regular review of privileged account usage

5.3.14 Logon IDs and Passwords

Password Features:

- Minimum length (12+ characters recommended)
- Complexity requirements
- Password history (prevent reuse)
- Account lockout after failed attempts
- Expiration policies

Password Attacks:

- Brute force
- Dictionary attack
- Rainbow table attack
- Phishing / social engineering

5.3.15 Remote Access Security

- VPN with strong encryption (IKEv2, SSL/TLS)
- MFA mandatory for remote access
- Endpoint compliance checking
- Session timeout controls

5.3.16 Biometrics

Metric	Definition
FAR (False Acceptance Rate)	Accepted an impostor — security risk
FRR (False Rejection Rate)	Rejected legitimate user — usability issue
CER/EER (Crossover Error Rate)	Point where FAR = FRR; lower is better

5.4 Network and Endpoint Security

5.4.6 Virtual Private Networks (VPN)

- Encrypted tunnel over public network
- Protocols: IPSec, SSL/TLS, OpenVPN, IKEv2
- Types: Site-to-site, Remote access

5.4.12 Firewalls

Type	How It Works
Packet Filtering	Inspects IP/port headers only (Layer 3/4)
Stateful Inspection	Tracks connection state (Layer 3/4)
Application Layer (Proxy)	Deep inspection of content (Layer 7)
Next-Gen Firewall (NGFW)	Combines all above + IPS + DPI
WAF (Web Application Firewall)	Protects web apps from OWASP Top 10

DMZ (Demilitarized Zone)

- Network zone between external firewall and internal network
- Hosts public-facing servers (web, email, DNS)
- Isolates public services from internal network

5.4.14 Network Segmentation

- Divides network into separate zones
- Methods: VLANs, physical segmentation, SDN microsegmentation
- Limits lateral movement in case of breach

5.4.15 Endpoint Security

- **EDR** (Endpoint Detection and Response) — detect and respond to threats on endpoints
 - **XDR** (Extended Detection and Response) — correlates across endpoints, network, cloud
-

5.5 Data Loss Prevention (DLP)

Data States:

- **Data at Rest** — stored on disk/database
- **Data in Transit** — moving across network
- **Data in Use** — actively being processed

DLP Content Analysis Methods:

- Keyword matching
- Pattern matching (regex) — credit card numbers, SSNs
- Statistical analysis
- File fingerprinting

DLP Controls:

- Classify and tag sensitive data
 - Monitor and block unauthorized transfers
 - Encrypt sensitive data at rest and in transit
-

5.6 Data Encryption

Key Concepts

Term	Definition
Plaintext	Unencrypted data
Ciphertext	Encrypted data
Key	Secret value used in encryption
Algorithm	Mathematical transformation

5.6.3 Symmetric Encryption

- Same key for encryption and decryption
- Faster but key distribution is a challenge
- Examples: AES (128/256-bit), DES, 3DES

- Use case: Bulk data encryption

5.6.4 Asymmetric (Public Key) Encryption

- Key pair: Public key (encrypt/verify) + Private key (decrypt/sign)
- Slower but solves key distribution problem
- Examples: RSA, ECC
- Use case: Key exchange, digital signatures, SSL/TLS

5.6.8 Digital Signatures

- Signed with sender's **private key**
- Verified with sender's **public key**
- Provides: Authentication, Integrity, Non-repudiation

5.6.9 Digital Envelope

- Data encrypted with symmetric key (fast)
- Symmetric key encrypted with recipient's public key
- Combines speed of symmetric + security of asymmetric

5.6.10 Applications

- **TLS/SSL** — secures web traffic (HTTPS)
- **IPSec** — encrypts IP packets at network layer
- **SSH** — secure remote access and file transfer

5.6.14 Email Security

Common Email Attacks:

- Phishing, spear phishing, whaling
- Business Email Compromise (BEC)
- Email spoofing

Email Security Controls:

- **SPF** — identifies authorized mail servers
- **DKIM** — digital signature on email headers
- **DMARC** — policy for SPF/DKIM failures
- Email encryption (S/MIME, PGP)

- Anti-spam and anti-malware gateways
-

5.7 Public Key Infrastructure (PKI)

PKI Components:

- **CA** (Certificate Authority) — issues digital certificates
- **RA** (Registration Authority) — verifies identity for CA
- **CRL** (Certificate Revocation List) — list of revoked certificates
- **OCSP** — Online Certificate Status Protocol (real-time revocation check)

Digital Certificate Contents:

- Subject name
- Public key
- CA digital signature
- Validity period
- Serial number

Certificate Revocation:

- CRL — periodic list (lag time issue)
 - OCSP — real-time status check (preferred)
-

5.8 Cloud and Virtualized Environments

5.8.1 Virtualization

- Multiple VMs on single physical host
- Hypervisor manages resource allocation
- VM escape — critical vulnerability in hypervisors

5.8.6 Containerization

- Lightweight virtualization (Docker, Kubernetes)
- Containers share host OS kernel
- Security: image scanning, registry controls, runtime monitoring

5.8.8 Shared Responsibility Model

Cloud Deployment Models:

Model	Control
Public Cloud	Lowest control, highest scalability
Private Cloud	Highest control, higher cost
Hybrid Cloud	Mix of public and private
Community Cloud	Shared by specific industry

Cloud Service Models:

Model	Customer Manages	Provider Manages
IaaS	OS, apps, data	Hardware, network
PaaS	Apps, data	OS, middleware, hardware
SaaS	Data only	Everything else

5.8.10 DevSecOps

- Security integrated throughout the development pipeline
 - "Shift left" — address security early in development
 - Automated security testing in CI/CD pipeline
 - Benefits: faster remediation, lower cost of fixes
-

5.9 Mobile, Wireless and IoT

5.9.3 Mobile Device Controls

- Screen lock / PIN / biometric
- Remote wipe capability
- Encryption of device storage
- MDM enrollment

5.9.5 BYOD (Bring Your Own Device)

- Policy defining acceptable personal device use
- Containerization — separate work and personal data
- Users must agree to MDM enrollment and remote wipe

5.9.9 Wireless Security

Protocol	Security Level	Notes
WEP	Very weak	Broken, do not use
WPA	Weak	Replaced by WPA2
WPA2	Strong	AES-CCMP encryption
WPA3	Strongest	SAE handshake, current standard

Wireless Threats:

- Evil twin access points
- War driving
- Rogue access points
- Man-in-the-middle

5.9.10 Internet of Things (IoT)

IoT Risks:

- Weak default credentials
- No patch management capability
- Limited security controls
- Large attack surface

IoT Controls:

- Change default credentials immediately
 - Network segmentation (IoT VLAN)
 - Regular firmware updates
 - Disable unused features and ports
-

PART B: SECURITY EVENT MANAGEMENT

5.10 Security Awareness Training

Security Awareness Program Elements:

- Onboarding training for all new employees
 - Annual refresher training
 - Role-based training (e.g., developers, finance users)
 - Phishing simulation exercises
 - Metrics: training completion rates, phishing click rates
-

5.11 Information System Attack Methods

OWASP Top 10 (Critical Web Application Risks)

1. Broken Access Control
2. Cryptographic Failures
3. Injection (SQL, LDAP, OS)
4. Insecure Design
5. Security Misconfiguration
6. Vulnerable and Outdated Components
7. Identification and Authentication Failures
8. Software and Data Integrity Failures
9. Security Logging and Monitoring Failures
10. Server-Side Request Forgery (SSRF)

5.11.4 Malware Types

Type	How It Spreads	Key Characteristic
Virus	User action required	Attaches to files
Worm	Self-propagating	Exploits network vulnerabilities
Trojan	Disguised as legitimate software	Does not self-replicate
Ransomware	Phishing, vulnerabilities	Encrypts files, demands payment
Spyware	Drive-by download	Collects information secretly
Rootkit	Advanced exploits	Hides in OS, hard to detect
Keylogger	Bundled with software	Records keystrokes

5.11.5 Ransomware Response

1. Isolate infected systems immediately
 2. Notify incident response team
 3. Preserve forensic evidence
 4. Assess backups for recovery
 5. Report to law enforcement (if required)
 6. Do NOT pay ransom (FBI recommendation)
-

5.12 Security Testing Tools and Techniques

5.12.3 Vulnerability Assessments

- Automated scanning to identify known vulnerabilities
- Tools: Nessus, OpenVAS, Qualys
- Does NOT exploit findings
- Produces list of vulnerabilities with severity ratings

5.12.4 Penetration Testing

Phases:

1. Planning and Reconnaissance
2. Scanning and Enumeration

3. Exploitation
4. Post-Exploitation
5. Reporting

Types by Knowledge:

Type	Tester Knows
Black Box	Nothing about target
White Box	Full documentation and credentials
Grey Box	Partial knowledge

Vulnerability Assessment vs. Penetration Testing:

- VA: Identifies vulnerabilities (passive)
 - Pentest: Exploits vulnerabilities (active) — requires written authorization
-

5.13 Security Monitoring Logs, Tools and Techniques

5.13.2 Intrusion Detection Systems (IDS)

- **HIDS** — Host-based, monitors individual system
- **NIDS** — Network-based, monitors network traffic
- **Signature-based** — matches known attack patterns
- **Anomaly-based** — detects deviations from baseline (more false positives)

IDS Limitations:

- Cannot prevent attacks (only detect)
- High false positive rate
- Cannot inspect encrypted traffic

5.13.3 Intrusion Prevention Systems (IPS)

- **Inline** — can block traffic in real-time
- More active than IDS
- **Honeypots** — decoy systems designed to attract attackers; gathers threat intelligence

5.13.6 SIEM (Security Information and Event Management)

Benefits:

- Centralized log collection and correlation
- Real-time alerting on suspicious activity
- Compliance reporting
- Forensic investigation support

SIEM Features:

- Log aggregation from all sources
 - Correlation rules and threat detection
 - Dashboards and reporting
 - Long-term log retention
 - Integration with threat intelligence feeds
-

5.14 Security Incident Response Management

5.14.1 Incident Response Process (NIST SP 800-61)

1. **Preparation** — policies, tools, team
2. **Detection & Analysis** — identify and confirm incident
3. **Containment** — limit damage spread
4. **Eradication** — remove root cause
5. **Recovery** — restore normal operations
6. **Post-Incident Activity** — lessons learned, report

5.14.2 CSIRT (Computer Security Incident Response Team)

- Dedicated team for handling security incidents
- Defined roles: incident coordinator, forensics, legal, communications

5.14.4 SOAR (Security Orchestration, Automation and Response)

- Automates repetitive incident response tasks
- Integrates multiple security tools
- Improves response speed and consistency

5.15 Evidence Collection and Forensics

5.15.3 Phases of Computer Forensics

1. **Identification** — recognize potential evidence
2. **Preservation** — protect from alteration
3. **Collection** — gather evidence using forensic tools
4. **Analysis** — examine evidence
5. **Presentation** — report findings in court-ready form

5.15.4 Audit Considerations

- **Data Acquisition** — bit-for-bit image (forensic copy) of media
- **Imaging** — use write blockers to prevent modification
- **Chain of Custody** — documented record of who handled evidence
- **Hash Verification** — MD5/SHA-256 hash confirms evidence not tampered with

5.15.7 Chain of Custody

- Must be maintained from collection through court presentation
- Documents: who collected, when, where, how it was stored, who accessed it
- Any break in chain can make evidence inadmissible

5.15.8 Best Practices for Digital Evidence

- Never work on original — always use forensic copy
- Document everything
- Use write blockers
- Maintain hashes to verify integrity
- Store in secure, access-controlled facility

QUICK REFERENCE — Key Formulas and Numbers

Concept	Formula / Value
---------	-----------------

ALE	$ARO \times SLE$
-----	------------------

Concept	Formula / Value
Residual Risk	Inherent Risk – Control Effectiveness
Best backup strategy	3-2-1 (3 copies, 2 media, 1 offsite)
RTO	Max tolerable downtime
RPO	Max tolerable data loss
CER/EER	Where FAR = FRR (lower = better biometric)
Type II Error	Beta risk — accepting bad population (worse)
MFA	2+ authentication factors

QUICK REFERENCE — Common Acronyms

Acronym	Full Form
CISA	Certified Information Systems Auditor
COBIT	Control Objectives for IT
CSA	Control Self-Assessment
SDLC	System Development Life Cycle
BIA	Business Impact Analysis
BCP	Business Continuity Plan
DRP	Disaster Recovery Plan
RTO	Recovery Time Objective
RPO	Recovery Point Objective
IAM	Identity and Access Management
PAM	Privileged Access Management
SIEM	Security Information and Event Management
SOAR	Security Orchestration Automation and Response

Acronym	Full Form
DLP	Data Loss Prevention
PKI	Public Key Infrastructure
CA	Certificate Authority
CRL	Certificate Revocation List
SLA	Service Level Agreement
CAB	Change Advisory Board
CMDB	Configuration Management Database
EUC	End-User Computing
GRC	Governance, Risk and Compliance
ERM	Enterprise Risk Management
ZTA	Zero-Trust Architecture
WAF	Web Application Firewall
NGFW	Next-Generation Firewall
EDR	Endpoint Detection and Response
XDR	Extended Detection and Response
IDS	Intrusion Detection System
IPS	Intrusion Prevention System
VPN	Virtual Private Network
DMZ	Demilitarized Zone
MFA	Multi-Factor Authentication
SSO	Single Sign-On
FIM	Federated Identity Management

